

Vulnerabilidades Remediadas y Aceptadas

Resumen

Se compararon los escaneos pre-hardening ([analisis/pre-hardening/MDs](#)) y post-hardening ([analisis/post-hardening/MDs](#)). El endurecimiento incluyó: uso de imágenes base versionadas, multi-stage builds en servicios Node, usuarios no privilegiados, [no-new-privileges/cap_drop](#), WAF y HTTPS en gateway, y eliminación de puertos expuestos (DB).

Vulnerabilidades principales encontradas (pre-hardening)

- Múltiples CVEs en imágenes base de Nginx, Postgres, Redis, Grafana stack (grafana/loki/promtail/prometheus) y servicios Node (todas las imágenes [projectou2_adminredes-*](#) reportaban CVEs diversas).
- Ejemplos frecuentes en pre-hardening:
 - Nginx Alpine: CVE-2024-58251, CVE-2025-46394, CVE-2025-10966, CVE-2025-64505/64506/64720/65018.
 - Postgres 15 Alpine: CVE-2025-58187/58188/61723/61725 (7.5), 58185/58186/58189 (5.3), 58183 (4.3), 58251 (2.5), 47912 (5.3), 62813 (3.1).
 - Grafana/Loki/Promtail/Prometheus pre: alto número de CVEs de severidad baja-media.
 - Servicios Node pre: CVEs acumuladas en dependencias/Alpine.
 - Redis 7 Alpine: varias CVEs medias/altas.

Cómo se corrigieron

- **Actualización de imágenes base y rebuilds:** Se fijaron versiones explícitas (Node 18.18.2-alpine, Grafana 10.4.3, Loki/Promtail 2.9.5, Redis 7-alpine, Postgres 15-alpine, Nginx:alpine) y se reconstruyeron servicios (post-hardening MDs muestran CVEs distintas/reducidas respecto a pre).
- **Hardening de contenedores:** Usuarios no root en servicios backend/monitoring, [security_opt: no-new-privileges](#), [cap_drop: \[ALL\]](#), redes internas sin exponer DB.
- **Gateway/WAF/HTTPS:** Nginx con TLS, headers de seguridad, rate limiting y bloqueo de User-Agents maliciosos.
- **Configuración DB:** Rol de aplicación con privilegios mínimos, sin puerto expuesto al host.
- **Centralización de logs:** Promtail/Loki/Grafana para trazabilidad.

Vulnerabilidades aún presentes (post-hardening) y mitigaciones pendientes

Top CVEs recurrentes en [analisis/post-hardening/MDs](#):

- CVE-2025-5889 (baja, 1.3) en todas las imágenes Node custom.
- CVE-2024-13176, CVE-2024-9143, CVE-2025-26519, CVE-2024-5535, CVE-2024-4741, CVE-2024-2511, CVE-2024-6119, CVE-2023-42363, CVE-2024-4603: presentes en Grafana/Loki/Promtail y microservicios Node.

Mitigación pendiente:

- Actualizar imágenes base (Alpine/Node, Grafana/Loki/Promtail/Prometheus, Nginx, Postgres, Redis) a versiones más recientes y volver a escanear.
- Automatizar escaneo (Trivy/Scout) en CI y política de parches recurrente (mensual y hotfix para críticas).

Vulnerabilidades aceptadas (con justificación)

- **Ejecución como root en Nginx (gateway/frontends):** Imagen oficial realiza `chown` en `/var/cache/nginx`; con `no-new-privileges` fallaba el arranque. Mitigación futura: imagen derivada con permisos pre-creados o `tmpfs` en cache y `USER` no root. Aceptado temporalmente para asegurar disponibilidad.
- **CVEs de baja severidad (p.ej. CVE-2025-5889, severidad 1.3) en servicios Node:** aceptadas temporalmente a la espera de nuevo ciclo de parches; impacto bajo y sin exploit conocido en nuestro contexto. Plan: rebuild con Alpine/Node actualizados y re-scan.
- **CVEs residuales en Grafana stack (medias/bajas):** aceptadas temporalmente hasta actualizar a próximas releases estables; riesgo mitigado por red interna y acceso restringido.